

Phishing investigation playbook

This article demonstrates a phishing playbook. It's part of the incident response playbook guidance in the [Security Operations \(SecOps\)](#) discipline.

This playbook is intended for all roles responsible for building or executing incident response playbooks, including SecOps analysts, incident responders, identity administrators, and IT operations staff.

Phishing attacks are one of the most common initial access techniques used by adversaries. A successful phishing attack can lead to credential compromise, malware execution, data exfiltration, and lateral movement across identity, email, and endpoint environments.

The guidance in this article describes what to investigate and why. Product-specific examples (such as Microsoft Defender XDR or Microsoft Sentinel) are provided as reference implementations.

Before you start

Before starting a phishing investigation, ensure that the following baseline readiness requirements are in place. These prerequisites should be completed before an incident occurs as part of incident response planning.

 Expand table

Area	Requirement	Details
Account information	Have at least one identifier for the suspected target user	Identifiers can be: user principal name (UPN), email address, or username/alias. This information is required to correlate email activity, sign-ins, and downstream actions.
Microsoft 365 audit/logging	Mailbox auditing should be enabled organization-wide to ensure that mailbox access and actions are recorded.	Verify that mailbox auditing on by default is enabled by running the following command in Exchange Online PowerShell: <i>Get-OrganizationConfig Format-List AuditDisable/</i> . A value of False indicates that mailbox auditing is enabled for all mailboxes.

Area	Requirement	Details
Microsoft 365 audit/logging	Message trace logs are required to identify the original phishing message, deliver status, all recipients, message routing details.	Message trace is available in Exchange Admin Center , Microsoft Defender portal (Email & collaboration > Exchange message trace). To work effectively with message trace data, investigators must be able to retrieve and interpret Message-ID values, which are obtained from raw email headers.
Microsoft 365 audit/logging	Unified audit logs are required to review user and administrative activity across Microsoft 365 workloads.	Ensure investigators can search the unified audit log to review actions such as mailbox access, mail item actions, administrative changes, and sign-in-related events.
Microsoft Entra logs	Microsoft Entra ID sign-in and audit logs are retained for a limited period (30 or 90 days, depending on licensing).	To support investigations, historical analysis, and post-incident review, export logs to a long-term repository such as Microsoft Sentinel, Azure Monitor, or a third-party SIEM.
Permissions	Ensure investigators have sufficient permissions to access required data without over-privileging accounts.	Microsoft Entra ID: minimum recommended role is Security Reader. Defender portal and Microsoft Compliance portal: Security Reader. These roles provide read-only access to email, alerts, and audit data.
Endpoint visibility	Microsoft Defender for Endpoint	If Defender for Endpoint is installed, use it to: - Validate whether users interacted with phishing content. - Identify payload execution. - Correlate endpoint activity with email events.
Hardware	A system capable of running PowerShell.	
Software	These PowerShell modules are commonly used during phishing investigations	Microsoft Graph PowerShell SDK Exchange Online PowerShell module Microsoft Entra Incident Response PowerShell module. Ensure all modules are installed and kept up to date.

Workflow

The phishing investigation workflow follows these high-level stages:

1. Identify and confirm the phishing message.
2. Scope the impact and affected users.
3. Assess user interaction and credential exposure.
4. Identify downstream activity.
5. Contain the threat and prevent recurrence

This workflow helps responders move from detection to containment without skipping critical validation steps.

What to check

Use this checklist as a quality gate during the investigation.

- Identify the phishing email and original Message-ID
- Determine all recipients and delivery status
- Identify whether users interacted with the message
- Assess credential compromise or malware execution
- Identify lateral or follow-on activity
- Remove malicious messages from mailboxes
- Reset or secure impacted accounts
- Improve detections and prevention controls

Investigation steps

Step 1: Identify the phishing message

1. Obtain the suspected phishing email.
2. Extract the Message-ID from the email headers.
3. Use message trace to determine:
 - When the message was received
 - Which users received it
 - Whether it was delivered, blocked, or quarantined

Step 2: Scope affected users

1. Identify all recipients of the message

2. Confirm whether the message bypassed filters
3. Determine whether similar messages were sent using variants of the same campaign

Step 3: Assess user interaction

1. For each affected user, determine whether they:

- Opened the email
- Clicked links
- Opened attachments
- Submitted credentials

Correlate email activity with:

- Microsoft Entra sign-in logs
- Audit logs
- Endpoint activity (if available)

Step 4: Identify follow-on activity

1. If credentials may have been exposed, investigate for:

- Suspicious sign-ins
- Password spray or brute force activity
- OAuth consent grants
- Token abuse
- Unusual mailbox or collaboration activity

2. If attachments were opened, validate whether any malware executed on endpoints.

Step 5: Contain and remediate

Based on findings:

1. Remove phishing messages from all mailboxes. Disable or reset.
2. compromised accounts.
3. Revoke active sessions and tokens.
4. Block malicious senders, domains, and URLs.
5. Isolate or remediate impacted endpoints.

Step 6: Recovery

After containment, focus on restoring normal operations and reducing recurrence risk.

Recovery actions may include:

- Enforcing credential resets and multifactor authentication
- Reviewing mailbox rules and forwarding settings
- Improving email filtering and anti-phishing policies
- Updating detections and alerts
- Updating or refining phishing response playbooks

Next steps

[Learn more](#) about the SecOps discipline.

Last updated on 05/31/2026